

SMART CONTRACT SECURITY AUDIT - LOTERY

One-Page Visual Audit Report

Purpose: Ticket-based lottery with players, ticket accounting and winner selection.

Risk	Severity	SWC	OWASP
drawWinner() accepts caller-supplied randomness and is predictable/manipulable	Critical	SWC-120	SC02 Business Logic
Ticket weights are not represented in players array; odds are unfair	High	N/A	SC02 Business Logic
Winner selection uses contract balance as poolWeight, distorted by direct ETH transfers	Medium	N/A	SC02 Financial Risks
No payout, round finalization or owner/admin controls	Medium	N/A	SC02 Business Logic

Root Cause: Randomness and lottery accounting are not tied to a secure entropy source or a correct weighted ticket model.

Business Logic Findings: The lottery can return a manipulated winner and does not distribute funds. Extra ETH changes winner math without increasing player entries.

BENCHMARK METRICS

Time_seconds: 75 | Confidence: 0.95 | Total_findings: 4

Critical: 1 | High: 1 | Medium: 2 | Low: 0

Precision_estimate: 0.93 | Coverage_estimate: 1.00 | Risk_score: 88/100

GOLD STANDARD EVALUATION

TP: N/A | FP: N/A | FN: N/A | Precision: N/A | Recall: N/A | F1: N/A